Incidentes de Seguridad & CSIRT

UNLP - Facultad de Informática

Seguridad de la información

El objetivo es garantizar los siguientes atributos de la información:

- **Confidencialidad:** Garantiza que la información sólo sea accesible por las personas autorizadas.
- **Integridad:** Garantiza que la información sólo pueda ser modificada por quien está autorizado a hacerlo.
- **Disponibilidad:** Garantiza que los usuarios autorizados tienen acceso a la información y recursos relacionados cuando lo necesiten.

Vulnerabilidad

Una vulnerabilidad es una debilidad que pone en riesgo la seguridad de la información pudiendo permitir a un atacante comprometer la integridad, confidencialidad o disponibilidad de la misma.

La vulnerabilidad puede estar en cualquiera de los siguientes elementos:

- El sistema de información.
- Las comunicaciones.
- Los sistemas que almacenan la información.
- Las personas que intervienen.

> Es deseable / necesario encontrar las vulnerabilidades y eliminarlas lo antes posible.

Amenazas

Una amenaza es toda acción que aprovecha una vulnerabilidad para atentar contra la seguridad de un sistema de información.

Las amenazas pueden concretarse a partir de:

- **Ataques informáticos:** ingeniería social, brute force, vuln-exploit, etc.
- **Sucesos físicos:** incendios, inundaciones, terremotos, etc.

Desde el punto de vista de una organización, las amenazas pueden proceder tanto de personal interno como externo.

Esquema de Clasificación de Amenazas

```
AMENAZAS
├── Naturales (Incendios, terremotos, inundaciones, etc.)
└── Humanas
    ├── Maliciosas
    │   ├── Internas
    │   └── Externas
    └── No Maliciosas
        └── Impericia
```

Incidente de seguridad

Un incidente de seguridad es un evento adverso que afecta la seguridad de la informacion.

Un incidente de seguridad se produce cuando se concreta una amenaza.

Algunos ejemplos de incidentes de seguridad que pueden afectar a una organización:
- Defacement.
- Ransomware.
- Robo de contraseña.
- Fuga de información confidencial.
- Compromiso de un hosts, servidor o servicios.
- Acceso no autorizado.
- etc

Las organizaciones canalizan la gestión de los incidentes de seguridad en un area

CERT / CSIRT

Los equipos encargados de la gestion de los incidentes de seguridad en las organizaciones se conocen como **CERT** o **CSIRT**.

Los **CSIRTs** tienen una comunidad objetivo a la que se dedican. Generalmente es la organizacion a la que pertenecen.

Los incidentes de seguridad de interés son los que afectan a la organizacion (sus usuarios y sus servicios), así como también los que afectan a terceros pero tienen su origen en la organización.

Gestión de incidentes de seguridad

La gestión de incidentes de seguridad implica:

- Recepción de incidentes.
- Evaluar su pertinencia.
- Clasificación / Priorización.
- Gestión del incidente:
  - Realizar distintos tipos de notificaciones.
  - Coordinar acciones.

Recepción

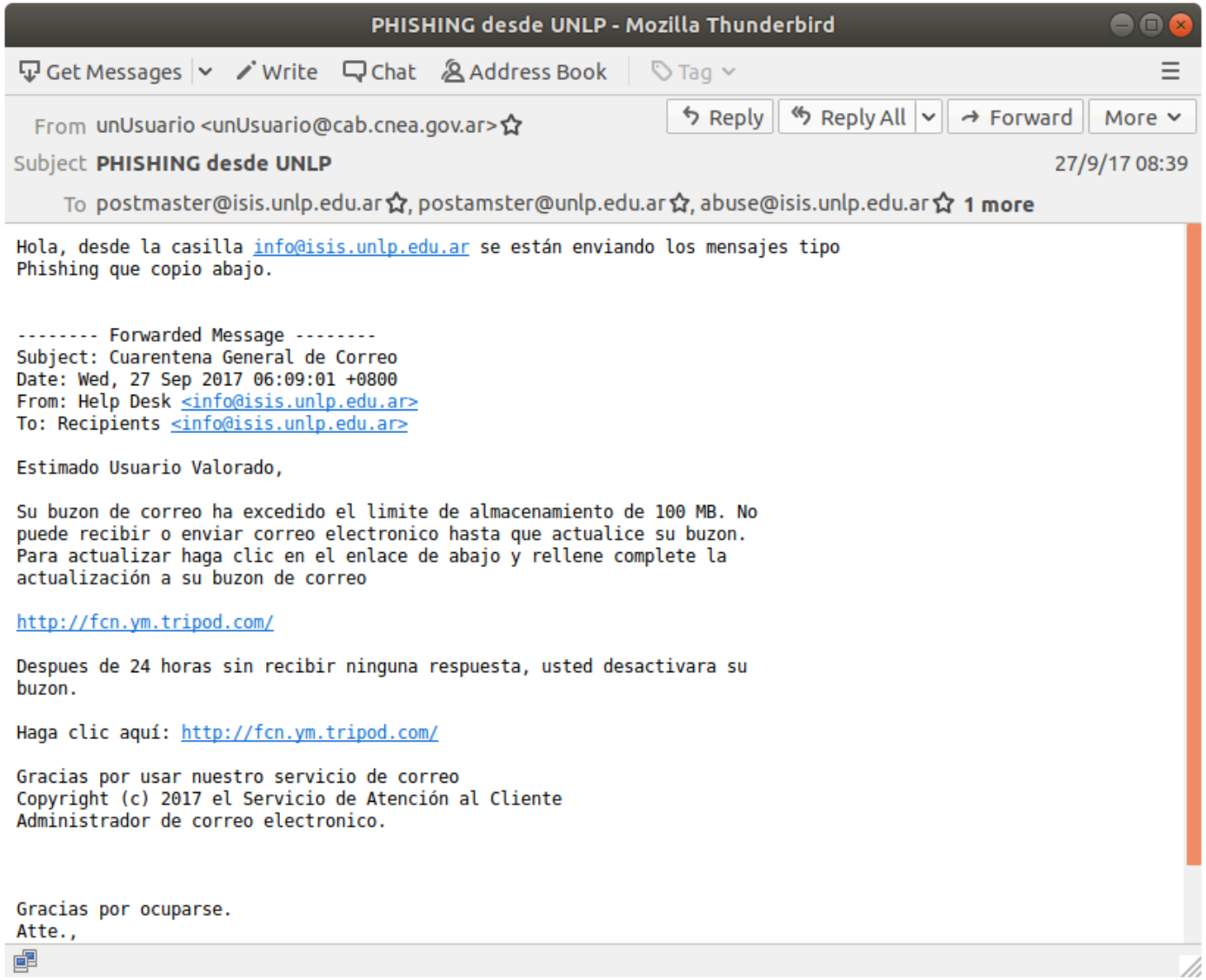
Los reportes pueden provenir de:

- Un usuario de nuestra comunidad objetivo.
- Un usuario externos:
    - WHOIS / RDAP
- Herramientas que podamos tener realizando distintos tipos de funciones:
    - Monitoreo de seguridad de la red.
    - Análisis de vulnerabilidades.

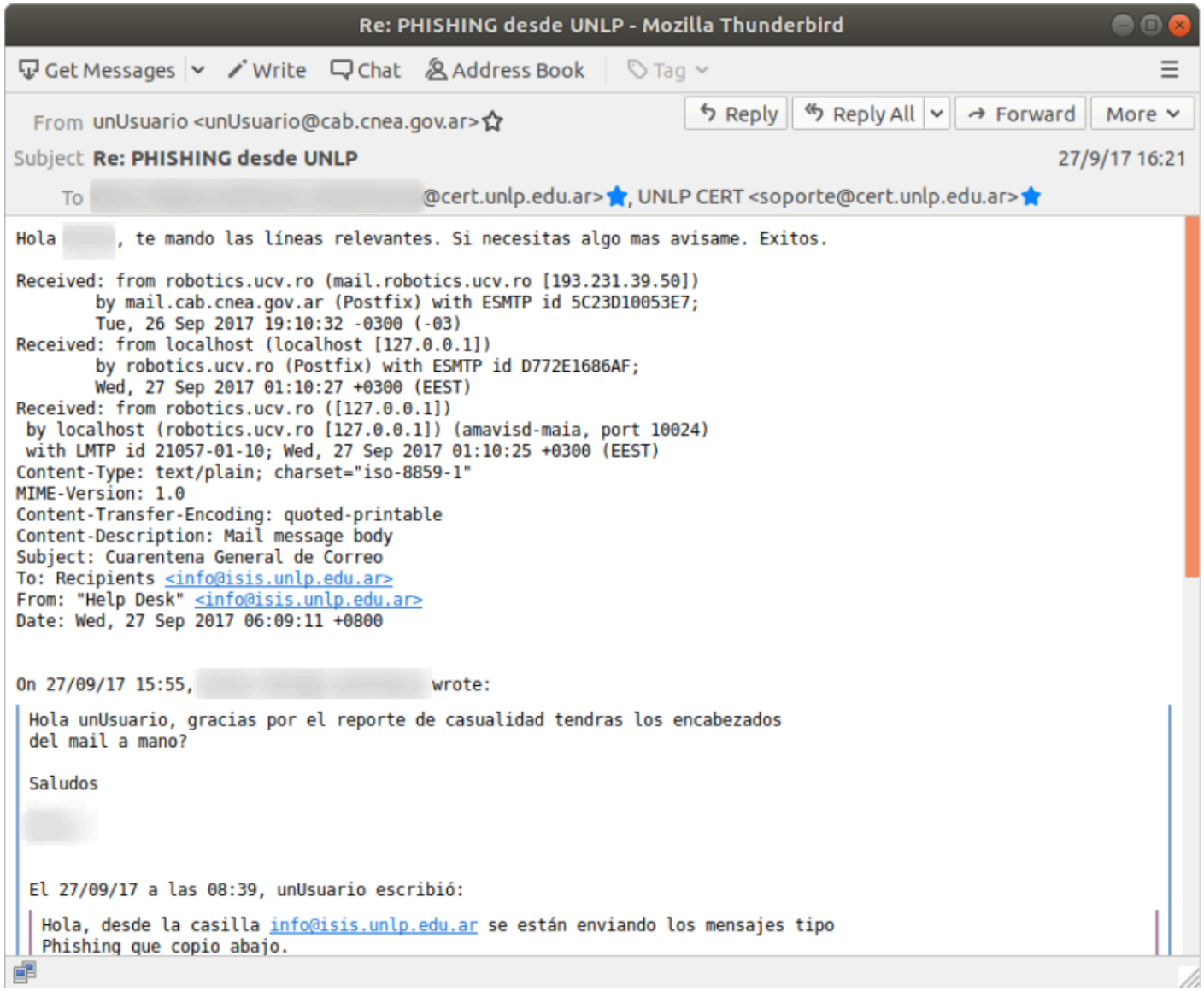
Pertinencia

- No todo lo que nos reportan es un incidente.
- Para determinar si lo que nos reportan es un incidente de seguridad, debemos fijarnos si:
  - Afecta a alguien de nuestra comunidad objetivo.
  - Es ocasionado por un recurso de nuestra comunidad objetivo.

¿Es pertinente?



¿y ahora? ¿Es pertinente?



Clasificación / Priorización

- Los incidentes se clasifican y priorizan en función de su criticidad.
- En caso de tener muchas cosas para gestionar, conviene dirigir los esfuerzos a los incidentes más importantes.
- La criticidad puede ser estimada a partir de:
  - El tipo de incidente.
  - Los recursos afectados por el incidente.
  - El impacto que podría tener en actividades críticas de la organización.

Clasificación de algunos incidentes frecuentes

Incident Types (7/54)			
Name			
cryptojacking	Scan	DOS SNMP	Open VNC
Undefined	Shellshock	Open DNS	Cisco Smart Install
Open LDAP	SSL Poodle	Open Elasticsearch	Data Breach
Open MongoDB	Suspicious Behavior	Open IPMI	Open MDNS
Open SNMP	Phishing Mail	Open NTP monitor	Bruteforce
Phishing Web	RPZ Botnet	Open SSDP	Copyright
RPZ DBL	RPZ Malware Aggressive	Open Telnet	Drupal Remote Code Execution
RPZ Drop	DOS NTP	Botnet	Heartbleed
RPZ Malware	Open Chargen	Deface	Malware
Poodle	Open MSSQL	DNS zone transfer	Open memcached
Spam	Open SMB	Information Leakage	Open QOTD
SQL Injection	Open TFTP	Open ISAKMP	Open RDP
Open NTP version	Blacklist	Open NetBios	
Open Portmap	DOS chargen	Open Redis	

Ejemplo priorización

Una buena práctica para priorizar eventos es, por ejemplo, utilizar niveles de prioridad:

- Incidentes de prioridad baja: envio de spam o malware desde una PC de la sala de PCs.
- Incidentes de prioridad alta: DB con datos sensibles expuesta a Internet.

Ejemplo priorización (cont: terceros)

El impacto a terceros puede incrementar la prioridad del incidente puesto que puede afectar la imagen de la organizacion.

- Todas las PCs de una sala de PCs infectadas con un malware que realiza un ataque de DOS a un servidor externo.

Ejemplo priorización (cont: assets)

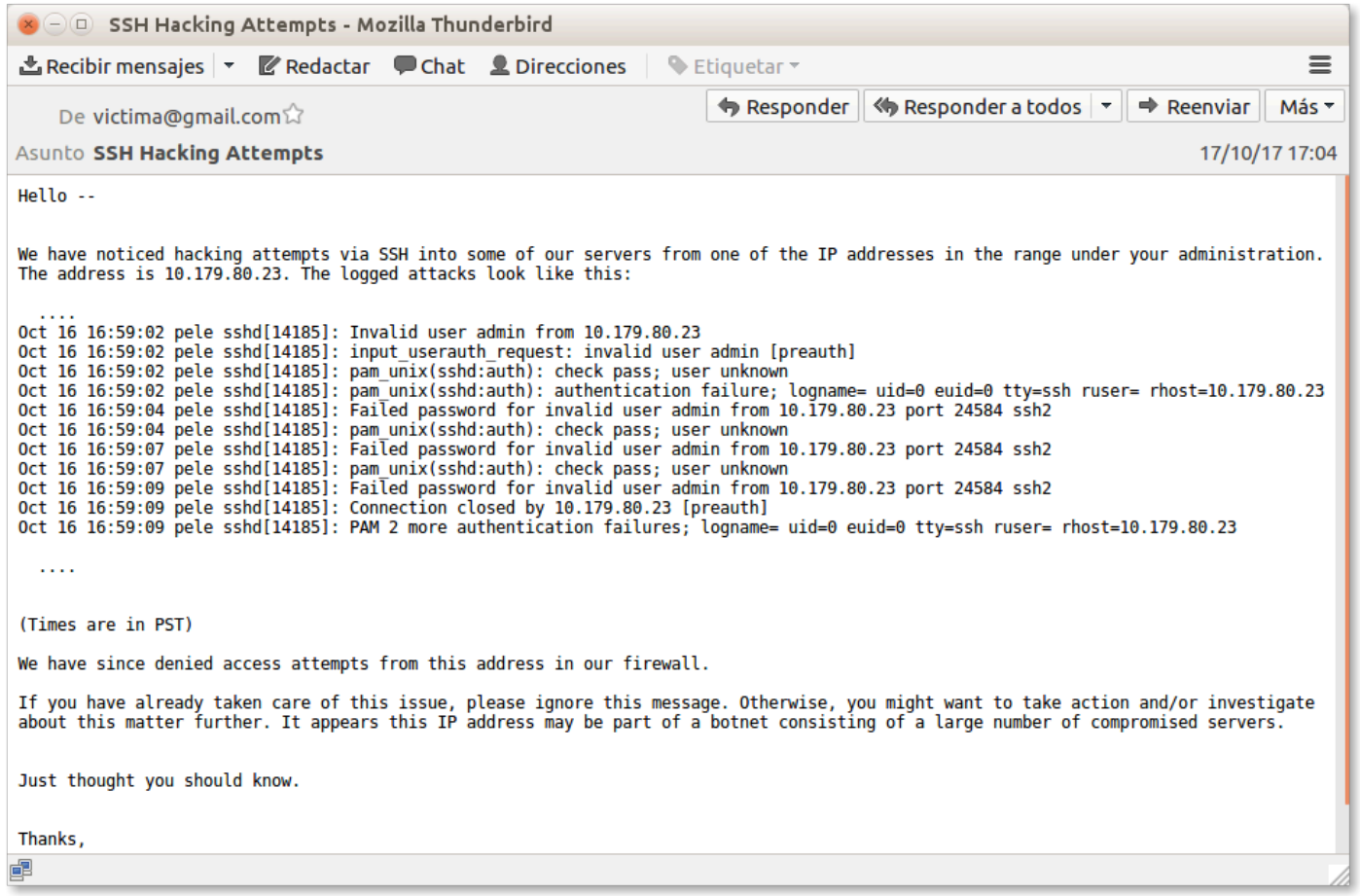
El impacto en la organizacion es otra veriable a considerar. El asset afectado involucrado en un incidente puede incrementar su prioridad

- Por ejemplo, un incidente de prioridad baja en un sistema crítico de la organización

Notificación

- La notificación de un incidente de seguridad es un aspecto clave en el proceso de resolución del mismo.
    - En esta etapa se contacta y comunica al responsable de un determinado recurso, los hechos relevantes que ayuden en la resolución del incidente.
    - Se debe proporcionar evidencia para que las partes implicadas puedan investigar el incidente y actuar en consecuencia.
- Importante
    - Determinar el contacto adecuado para la notificacion.
    - Dar registros del incidente con timestamps asociados.
    - Informar la zona horaria de los timestamps.

Ejemplo notificación



Otras siglas usadas por CERTs / CSIRTs

Sigla	Significado
CSIRT	Computer Security Incident Response Team
CERT	Computer Emergency Response Team
CSIRC	Computer Security Incident Response Capability
CIRC	Computer Incident Response Capability
CIRT	Computer Incident Response Team

Otras siglas usadas por CERTs / CSIRTs (Continuación)

Sigla	Significado
IHT	Incident Handling Team
IRC	Incident Response Center or Incident Response Capability
IRT	Incident Response Team
SERT	Security Emergency Response Team
SIRT	Security Incident Response Team

> No importa si se llama CERT o CSIRT. Lo importante es que gestionan incidentes de seguridad.

Servicios que provee un CSIRT

Servicios reactivos

```
- Alertas y advertencias.
- Gestión de incidentes.
- Análisis forense.
```

Servicios proactivos

```
- Auditorías o evaluaciones de seguridad.
- Desarrollo de herramientas de seguridad.
- Servicios de detección de intrusiones.
```

Servicios de gestión de calidad de seguridad

```
- Planificación de continuidad del negocio y recuperación ante desastres.
- Consultoría en seguridad.
- Concientización.
- Educación / Capacitación.
```

Buenas Prácticas

Los miembros de un CSIRT deben manejar con cuidado la información relacionada a los incidentes de seguridad gestionados. Para ello:

- Se mantiene la **confidencialidad** de la información de modo que solamente el afectado tenga acceso.
- En caso de ser necesario intercambiar información sensible con otros CSIRTs o afectados, se utiliza un protocolo conocido como **TLP** para que el destinatario sepa con quién puede compartir la información.
- Se utiliza criptografía (**PGP**) para realizar el intercambio de información sensible de forma segura.

Traffic Light Protocol (TLP)

Esquema creado para un mejor intercambio de información sensible, pero no clasificada entre CSIRTs.

El autor de una información puede indicar a receptores hasta dónde puede circular la información dada.



Código	Cuándo utilizarlo	Cómo compartirlo
TLP:RED	Se debe utilizar TLP:RED cuando la información está limitada a personas concretas, y podría tener impacto en la privacidad, reputación u operaciones si es mal utilizada.	Los receptores no deben compartir información designada como TLP:RED con ningún tercero fuera del ámbito donde fue expuesta originalmente.
TLP:AMBER	Se debe utilizar TLP:AMBER cuando la información requiere ser distribuida de forma limitada, pero supone un riesgo para la privacidad, reputación u operaciones si es compartida fuera de la organización.	Los receptores pueden compartir información indicada como TLP:AMBER únicamente con miembros de su propia organización que necesitan conocerla, y con clientes, proveedores o asociados que necesitan conocerla para protegerse a sí mismos o evitar daños. El emisor puede especificar restricciones adicionales para compartir esta información.
TLP:GREEN	Se debe utilizar TLP:GREEN cuando la información es útil para todas las organizaciones que participan, así como con terceros de la comunidad o el sector.	Los receptores pueden compartir la información indicada como TLP:GREEN con organizaciones afiliadas o miembros del mismo sector, pero nunca a través de canales públicos.
TLP:WHITE	Se debe utilizar TLP:WHITE cuando la información no supone ningún riesgo de mal uso, dentro de las reglas y procedimientos establecidos para su difusión pública.	La información TLP:WHITE puede ser distribuida sin restricciones, sujeta a controles de Copyright.

Coordinación / TLP: Caso WannaCry

Ciberataque global [editar]

El 12 de mayo de 2017 entre las 8 y las 17:08 horas UTC[3] se registró un ataque a escala mundial que afectó a las empresas Telefónica[4] [5], Iberdrola y Gas Natural, entre otras compañías en España,[6] así como al servicio de salud británico, como confirmó el Centro Nacional de Inteligencia.[7] [8] [9] [10] [11] La prensa digital informaba aquel día que al menos 141 000 computadores habían sido atacados en todo el mundo.[12] [13] [14]

Subject **[Lac-csirts] WannaCry whitepaper** 15/5/17 10:15

To LAC-CSIRTs lista <lac-csirts >

Segue um whitepaper sobre o WannaCry, produzido pelo ThaiCERT.

Arquivo em anexo.

1 attachment: WannaCry_Ransomware_v1.0.pdf 1,0 MB Save

WannaCry Ransomware

Compiled by ThaiCERT, a member of the Electronic Transactions Development Agency

Version 1.0 (15 May 2017)

TLP:WHITE



PGP

En la operación de un CSIRT, distintas situaciones pueden requerir el intercambio de información de manera segura:

- Compartir datos sensibles entre miembros del equipo.
- Entregar informes de pentests realizados.
- Entregar informes de forensias realizadas.
- Para ello, es necesario disponer de formas seguras para el intercambio de información. Las posibilidades son:
    - Reunión presencial.
    - Uso de criptografía en las comunicaciones (**PGP**).